JOURNAL OF CYBERSECURITY

Journal of Cybersecurity, 2025, tyaf019
https://doi.org/10.1093/cybsec/tyaf019

Review Article

Learning from safety science: designing incident reporting systems in cybersecurity

Nico Ebert[1,*], **Thierry Schaltegger**[1], **Benjamin Ambuehl**[1], **Tim Geppert**[1], **Ariane Trammell**[2], **Melanie Knieps**[3], **Verena Zimmermann**[4]

[1]ZHAW School of Management and Law, Institute of Business Information Technology, Theaterstrasse 17, 8400 Winterthur, Switzerland
[2]ZHAW School of Engineering, Institute of Computer Science, Steinberggasse 13, 8400 Winterthur, Switzerland
[3]Digital Society Initiative, University of Zurich, Rämistrasse 69, 8001 Zurich, Switzerland
[4]Professorship for Security, Privacy and Society D-GESS, ETH Zurich, Stampfenbachstrasse 69, 8006 Zurich, Switzerland

*Corresponding author. ZHAW School of Management and Law, Institute of Business Information Technology, Theaterstrasse 17, 8400 Winterthur, Switzerland. E-mail: ebert@zhaw.ch

Received 23 January 2025; revised 24 June 2025; accepted 30 July 2025

Abstract

Despite all the technical approaches to monitoring threats and detecting incidents, manual incident reporting is critical at all organizational levels of cybersecurity. However, in its current state, reporting suffers from challenges such as underreporting, lack of reporting channels, and uncertainty about what should be reported. The phenomenon of incident reporting itself is not clearly defined and occurs in different facets, from reporting phishing emails to the IT department to reporting vulnerabilities to national authorities. This makes it difficult to design effective socio-technical incident-reporting systems (IRS) according to overarching principles. This review article addresses these challenges by drawing on insights from the field of safety, where IRS are well-established. We find that a broad range of events is reported, various reporting channels on different organizational levels exist, and key design factors of successful IRS have emerged. Based on these lessons from safety, we propose a taxonomy for cybersecurity reporting that includes noncritical events, such as near misses, and latent factors, such as weak security controls. We suggest that also in cybersecurity new reporting channels can be established, e.g. for reporting of noncritical events to nonpunitive supra-organizational bodies or for employee reporting. When designing IRS for cybersecurity, factors such as case-based learning, voluntariness, impunity, independence, and feedback should be taken into account in order to encourage reporting.

Keywords: cybersecurity; incident reporting; vulnerability reporting; safety science

Introduction

Since the introduction of IT security functions in the 1980s, organizations have relied on incident reporting—initially focusing on internal events, such as employee computer misuse [1]. In the late 1980s, the increasing interconnectedness of organizations through the Internet led to a rise of external events, such as the distribution of malware and the need for cross-organizational computer incident response teams (CSIRTs) to prevent incidents affecting multiple organizations [2]. These teams relied on manual incident reporting. Today, some organizations not only voluntary report incidents but are even obliged to report serious ones [3]. Thus, despite all technological innovations to automatically detect and report incidents, the human ability to recognize and report incidents remains central to cybersecurity [4, 5].

However, manual incident reporting is fraught with numerous challenges. A fundamental issue lies in the lack of a unified understanding of what incident reporting entails. It encompasses various forms, such as phishing reports by employees, the reporting of data breaches to national CSIRTs, or, in a broader sense, vulnerability reporting [6–8]. The ambiguity surrounding what qualifies as an incident often leads to uncertainty about what should be reported [3].

© The Author(s) 2025. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution License (https://creativecommons.org/licenses/by/4.0/), which permits unrestricted reuse, distribution, and reproduction in any medium, provided the original work is properly cited.

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

Reporting obligations are fractured across countries [9]. Furthermore, structured reporting channels are frequently absent, complicating the reporting process [10]. And even when reporting occurs, its effectiveness is not guaranteed: a dual problem of underreporting relevant incidents and overreporting irrelevant ones is commonly observed [4, 11]. Additionally, the absence of follow-up actions to the reports often renders them ineffective, as they fail to translate into appropriate measures [11, 12]. This overall deficit in clarity and structure hinders the development of effective reporting systems and the optimal use of human capabilities to detect and report incidents [13].

This is where the safety discipline offers solutions. Established ideas and concepts from the field of safety are already being adapted for cybersecurity (e.g. cyber-resilience systems [14]). Researchers have started to systematically translate safety knowledge to the cybersecurity domain [15, 16]. The main rationale for the transfer is that many problems and solutions are similar. For example, while cyberattacks are carried out intentionally, unlike accidents, the need for organizations to protect themselves is similar [17, 18]. However, safety has a decades-long experience advantage in the development of holistic prevention concepts that do not only involve isolated technical aspects but the organization as a whole [16].

Also in safety, incident reporting is considered a cornerstone of all safety measures—especially in high-risk industries [19–21]. Since the 1970s, incident reporting systems (IRS) have been implemented to enable individuals and organizations to report incidents, fostering a culture of safety and continuous improvement [22, 23]. Evidence suggests that incident reporting can foster organizational learning and ameliorate safety (e.g. in aviation [24], occupational safety [25], or patient safety [26]). In the aviation sector alone, NASA's voluntary Aviation Safety Reporting System (ASRS) has led to numerous safety improvements. For example, reports of distracting conversations between cockpit personnel during critical phases of a flight and consequential incidents led to the "Sterile Cockpit Rule" of the American air traffic control, which limits conversations to necessary coordination during taxi, takeoff, and landing [27]. Therefore, learning not only from severe but also from seemingly minor reports is seen as key to preparing for, mitigating, and preventing future events [23]. To achieve these goals, it was always necessary to look for ways to obtain human support, for example, through nurses reporting incidents in hospitals [28].

If we adapt the successful practices from safety and avoid mistakes of the past again, we can substantially improve reporting in cybersecurity, given its pivotal function [29–31]. Therefore, in this article, we review the literature on IRS in safety and assess the applicability of its insights to cybersecurity. Our guiding question is:

How are effective IRS designed for cybersecurity?

We first consider the purpose of incident reporting in both fields. Second, we propose a taxonomy to categorize what can be reported and describe areas we regard as currently neglected in cybersecurity. Third, we compare IRS on different organizational levels and show opportunities for new reporting channels. Fourth, based on a systematic review of previous literature, we outline key design considerations for IRS and their relevance for cybersecurity. Lastly, we discuss our findings and shed light on implications for researchers and practitioners.

Why report? The purpose of IRS

What is known as an IRS in safety is a socio-technical system facilitating the structured reporting, collation, and analysis of incidents [22]. IRS are employed locally in organizations but also on an industry or national and international level [22]. Initially, IRS were implemented in sectors such as aviation, chemical production, marine transportation, military, nuclear power production, railway transportation, and healthcare to increase safety through a better understanding of accidents and their causes [23 p. 14]. Central to this were systems for mandatory reporting of accidents to authorities for investigation, such as airplane accidents [32]. The scope of these systems was later broadened to include voluntary reporting of incidents considered precursors to accidents [21, 33]. An example is ASRS, launched in 1976 as an industry-wide system to gather, examine, and address aviation near misses (e.g. a near-aircraft collision) to minimize the risk of actual aviation accidents [34]. Voluntary reporting has evolved to become integral in enhancing safety [23].

Thus, a central question for the design of an IRS is what function it has (i.e. what purpose it serves), because the form and function of such a socio-technical system are closely intertwined [35]. Implemented by both the private and public sectors, the overall purpose of IRS is to institutionalize the improvement of safety in organizations. The following goals have been identified [23 p. 22, 1168, 35 p. 33, 36 p. 201, 37]:

- Learning from accidents and less severe events to improve safety by determining hazards, investigating the causes of incidents, finding patterns and trends, and identifying improvement measures.
- Assessing safety-related risks and cost reduction measures.
- Caring for victims of incidents, compensating victims, and demonstrating goodwill.
- Cultivating a safety culture within an organization by fostering a positive attitude and raising awareness.

Mandatory IRS additionally serve the following goal [36]:

- *Complying* with regulatory requirements for reporting, investigation, and record-keeping.

Also in cybersecurity, incident reporting has been recognized to enhance cybersecurity of organizations, industrial sectors, or even nations [37]. Unlike in safety, there is no single notion for the various reporting phenomena such as IRS [on closer inspection also safety uses different notions (e.g. near miss reporting systems), but we believe that the phenomenon of IRS is nevertheless more clearly defined.]. Instead, reporting exists in various forms, for example as part CSIRTs [2, 38, 39], as coordinated vulnerability disclosure [40], or employee phishing reporting [8]. Regarding the function, not only voluntary reporting but also mandatory reporting systems have been employed. For example, the Network and Information Security Directives (NIS/NIS2) in the European Union and the Cyber Incident Reporting for Critical Infrastructure Act (CIRCIA) in the USA require critical infrastructure organizations to report critical incidents [3, 6, 41]. Similarly, privacy legislation such as the EU General Data Protection Regulation (GDPR) obliges organizations to report breaches [41].

Consequently, we can say that the purpose of IRS in cybersecurity is very similar to that in safety: learning from incidents, risk assessment, promoting a security culture, fulfilling legal requirements, or informing those affected (e.g. in the event of a data breach) [38, 39, 42]. The consequences of cybersecurity incidents, such as business interruption or loss of data are often less tangible compared to the safety-related consequences, e.g. physical or psychological adverse impacts, for people (e.g. [20]). However, cyber incidents can also cause severe harm to individuals—for example, if cyber–physical systems, such as a pacemaker or an electric grid are hacked [43].

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

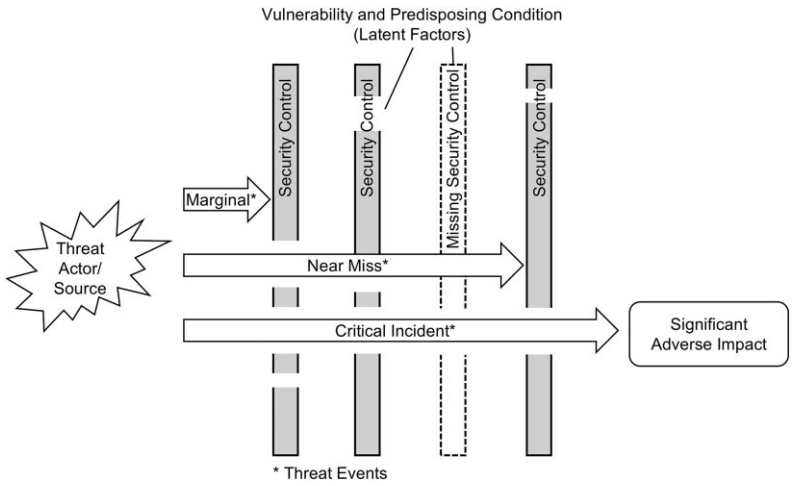


Figure 1. The Swiss Cheese Model [49] adapted for cybersecurity.

Given the many parallels, the question arises as to why the findings on safety reporting have not been systematically used for cyber security. One explanation might be that cybersecurity is still very monodisciplinary and silo-oriented, with a lack of understanding nontechnical aspects and consideration of other disciplines [44, 45]. In contrast, safety has grown to a highly interdisciplinary field which recognizes that IRS can only be successful if they are understood as part of a greater socio-technical system [46, 47].

Other reasons for the absence of knowledge transfer may be terminological confusion, a lack of abstraction of safety knowledge, or the (assumed) specificity of the cybersecurity context. For example, as discussed before, there is no comprehensive notion of IRS and related terms in cybersecurity despite various forms of de facto incident reporting. However, if cybersecurity views each type of reporting as unique and independent of one another, there will be no search for overarching solutions.

To overcome the differences between the disciplines, we will first discuss the reporting terminology before looking at different categories of reporting systems. In doing so, we will realize that certain forms of reporting do not yet exist in cybersecurity (e.g. near miss reporting).

What can we report? A look at what causes incidents

To understand what can theoretically be reported, it is instructive to look at what causes incidents. The discipline of safety has developed numerous types of "accident causation models" [48]. In the popular "Swiss Cheese Model" (The same type of thinking is often implicitly and explicitly implied in cybersecurity concepts such as the cyber kill chain, MITRE attack, depth-in-defense, or root cause analysis [16, 49].) a *hazard* may lead to an *accident* despite numerous *layers of defense*. An accident may occur if flaws (holes) caused by *latent factors* and *adverse events* in each layer of defense align [50]. Adverse events range from *minor incidents* (with no significant adverse impact) and *near misses* (with potentially significant adverse impact) to *actual accidents* (with a significant adverse impact) (See appendix for original safety definitions.). In safety IRS, all of these entities are reported. Reporting of hazards ranges from external hazards, such as "dangerous weather conditions in aviation" to internally created hazards such as "a bucket of slippery oil at a retail store" [51]. Latent factors are reported such as flight crew fatigue [52] or a lack of training. Finally, not only types of adverse events are reported but also their harm is reported (i.e. the consequences of an adverse event), such as the "negative side-effects of a medication" [53].

As shown in Fig. 1, the Swiss Cheese Model can be directly translated to cybersecurity using NIST's terminology [54, 55]. Due to the importance of the actor, we distinguish between threat actor and threat source (analogous to NIST SP 800–150), unlike safety, which only recognizes the hazard. A *threat actor* (e.g. attacker, malicious insider) and *threat source* (e.g. intention to exploit a common vulnerability, negligent user behavior) may initiate a *threat event* (*i.e. marginal incident*, *near miss or critical incident*), which exploits *vulnerabilities* and *predisposing conditions* (latent factors) in *layers of security controls* (Referred to as "security control effectiveness" in SP 800–137 [56].) (e.g. firewalls, network segmentation, processes, and awareness training). Critical incidents lead to *significant adverse impact*.

In cybersecurity IRS, each of the entities of the Swiss Cheese Model can be reported, too (see reporting taxonomy in Table 1). Reporting "a group of hackers exploiting a specific software vulnerability" to alert potential victim organizations [57] is an example of a threat actor (hackers) and threat source (intentional exploitation of a vulnerability). Within an organization also malicious insiders can be reported, for example, by colleagues [58, 59].

In the reporting of *threat events*, the distinction between critical incidents, near misses, and marginal incidents is typically not made [60]. While reporting of critical incidents and their impact (e.g. large financial loss or interruption of business) is often required by law, there is potential to report near misses and marginal incidents. Although proposed over 20 years ago and discussed in the research community now and then [29–31, 61], near miss reporting has only recently found its way into practice {e.g. [Article 6(5) NIS 2 Directive], [62]}. Reporting near misses could provide more frequent learning opportunities than critical incidents alone [63]. Individuals and organizations may be also less likely to withhold or strategically report in their own self-interest, given the lower importance and likelihood of negative consequences of reporting (e.g. no regulatory or civil liability) (Tamuz, 1988, p. 1ff.).

Latent factors in cybersecurity are either vulnerabilities (e.g. technical vulnerabilities, insufficient processes, lack of training, fatigue of SOC staff, and missing controls) or predisposing conditions (e.g. prioritizing the time to market for IT products over security, high degree

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

Table 1. Reporting taxonomy for cybersecurity based on the Swiss Cheese Model.

Entity (specific safety notion)	Definition	Example for a report
Threat actor (safety: n/a)	A person or group posing a threat source (e.g. malicious outsider, malicious or accidental insider) (NIST SP 800-150).	• A national CSIRT reports that a known "hacker group" is currently distributing malware via phishing emails. • Colleagues report a malicious insider.
Threat source (safety: hazard)	The intent and method targeted at the *intentional* exploitation of a vulnerability, or a situation and a method that may *accidentally* exploit a vulnerability (NIST 800-30 Rev.1).	• A CSIRT reports that a group intends to exploit a firewall vulnerability at Swiss banks. • A machine operator reports continuous equipment failures with potential security consequences.
Threat event (safety: adverse event)	An event or situation potentially causing undesirable consequences or impact (NIST 800-30 Rev.1).	
Marginal incident	A threat event with no potential for causing significant adverse impact (Definition see Appendix).	• The SOC reports an unsuccessful brute force attack on an MFA-protected login page. • A user reports that they have been receiving phishing emails despite an automated phishing filter. • An employee reports they "badged in" an unauthorized person to a secured premise.
Near miss	A threat event with the potential for causing a significant adverse impact that did not materialize. (Definition see Appendix).	• An engineer reports that an AWS bucket was publicly accessible due to misconfiguration but has not been accessed. • An account manager at a bank reports that they sent client data to their private email account but deleted the email immediately. • A user reports that malware is present on his PC, but this was halted by end-point security software.
Critical incident (safety: accident)	A threat event that has materialized, causing a significant adverse impact. (Definition see Appendix)	• Malware infects manufacturing computers and stops production. • Ransomware encrypts large amounts of personal data.
Latent factors	Inevitable "resident pathogens" within a system based on design or management decisions that combine with threat events. [69].	
Vulnerability	Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited by a threat source (NIST 800-30 Rev.1).	• A vendor reports that a vulnerability has been discovered in its VPN client deployed to a customer. • An internal software engineer reports a known software vulnerability that has not yet been fixed. • A student reports that she could circumvent the MFA configured for her account.
Predisposing condition	A condition that exists within an organization, a mission/business process, enterprise architecture, or information system [..], which contributes to [..] the likelihood that one or more threat events [..] will result in undesirable consequences or adverse impact [..] (NIST 800-30 Rev.1).	• An IT architect reports large amounts of hard-to-secure legacy systems. • A user reports the absence of a culture of security in their environment. • A medical doctor reports unnecessary external network connectivity of medical devices, which increases the probability of vulnerabilities.
Adverse impact (safety: harm)	Adverse impact describes the consequences of a threat event exploiting latent factors (adapted from NIST 800-30 Rev.1).	• A cloud provider reports that large amounts of data of an organization have been extracted by attackers and stored on the provider's systems. • A bank reports interruptions in operation caused by an attack to its regulator.

of networking of systems) [54]. They are currently not systematically reported in cybersecurity, apart from specific technical system vulnerabilities [64]: For example, employees could report account sharing practices or ineffective physical entry controls [65]. IT architects could report predisposing conditions, such as large degree of end-of-life software, which is potentially more vulnerable than more modern systems [66].

Reporting of *adverse impact* can range from minor impacts, such as locally deleted files on a PC to significant impacts such as financial loss, business interruption, or data breach. While significant impact is reported under today's regulations [e.g. (Article 13 GDPR), (Article 23 NIS 2 Directive)] and in cyber insurance claims [67], we are not aware of the reporting of less severe impacts with the sole goal of learning (e.g. through sharing between organizations of a sector).

How should we report? Different types of reporting systems

Having addressed the questions of why to report and what can theoretically be reported, the next question is how to report. We therefore compare different reporting systems including their channels [23].

IRS in safety have been established at the local level, allowing reporting to organizations by staff or external reporters. For example, in many hospitals, nurses and doctors are called upon to report incidents in organizational reporting systems [28]. Also staff in nuclear power plants is required to report safety issues [68].

Comparable structures on the organizational level can be identified in cybersecurity. Internal reporters can be security professionals or regular employees (Fig. 2, 1). For example, security teams

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

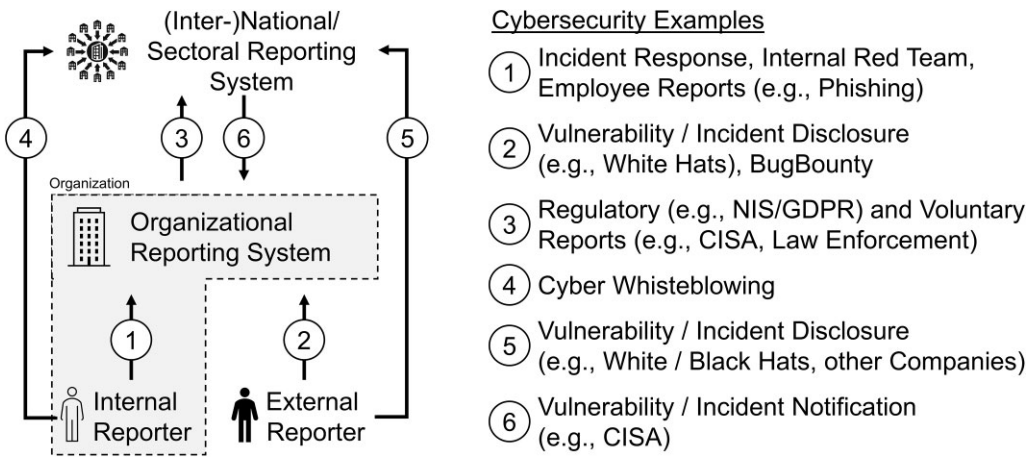


Figure 2. Possible IRS and channels (with cybersecurity examples).

monitor the IT infrastructure and report incidents to the management [69, 70]. In many organizations, regular employees can report phishing emails [8]. In the future, they could be also encouraged to report other types of observations that help to improve security (e.g. minor data breaches) [71–73]. However, in contrast to safety, reports by external reporters such as researchers, clients, or vendors are as relevant as internal reports for organizations because all parties are connected via the Internet (Fig. 2, 2). For example, external security researchers can report a vulnerability in an organization's web server. [7]. Still, only a few organizations have established standard processes for external reporters, such as web forms [74] or publicly accessible disclosure policies [10].

IRS in safety have also been established on higher levels than the individual organization (e.g. industry-wide systems such as ASRS, national safety systems at supervisory authorities) [32, 33]. They receive reports from organizations, both mandatory and voluntary, based on specific thresholds, and can actively report to organizations (e.g. known problems with a drug). However, regular employees can directly report to IRS, too. For example, in ASRS and in the UK Confidential Human Factors Incident Reporting Program (CHIRP), reports can be directly made by airline employees [52]. The information is then shared with the affected airline and the industry. The reason for direct reporting to the IRS is that organizations may be unresponsive to internal reports or unwilling to share information with external authorities.

In cybersecurity, these higher-level IRS correspond to sectoral and national CSIRTs, supervisory authorities, and cyber insurance providers. Recently cybersecurity, privacy, and financial legislations require organizations to report incidents to supervisory authorities [6, 41, 75]. Voluntary reporting is also possible, for example to sector-specific CSIRTs [76]. These higher-level IRS receive reports based on specific thresholds from organizations (e.g. severity of a data breach) (Fig. 2, 3). Reports can also be submitted by individual external reporters (e.g. security researchers) (Fig. 2, 5). IRS can then notify individual organizations, for example, about new vulnerabilities [77] (Fig. 2, 6). However, compared to safety, voluntary reporting of threats, near misses, vulnerabilities, and other security-relevant events to higher-level IRS is in its infancy [3]. Systems such as ASRS, in which employees report wrongdoing within organizations to higher-level IRS are also just evolving (Fig. 2, 4). At present, cybersecurity whistleblowing and dedicated reporting infrastructure are rare; Singapore's national cybersecurity whistle-blowing system is one of the few notable examples [78].

To conclude, there is potential in cybersecurity for more systematic reporting of a wider range of security observations, both to the IRS in the organization and to higher-level IRS. Both internal and external reporters should be supported with improved reporting channels (e.g. employee reporting beyond phishing). The reporting of noncritical incidents to sectoral or national CSIRTs still has room for improvement. In sectors with high security requirements, such as aviation, an IRS for whistleblowing similar to the ASRS for security could even be introduced.

How should we design reporting? Critical design themes

So far, we have established that IRS in safety and cybersecurity serve comparable purposes. By looking through the lens of the Swiss Cheese Model, we highlighted the potential to include noncritical incidents in cybersecurity reporting. Furthermore, we observed that, relative to safety, cybersecurity reporting could benefit from a more systematic approach both within organizations and with higher-level institutions. In this section, we will address the general design factors that need to be considered when introducing IRS in an organization. We do this by identifying relevant themes in the safety literature and discussing them in the context of cybersecurity.

Methodology

To identify critical design themes, we performed a systematic review following a concept-centric approach [79]. Due to the immense number of publications on the design of IRS in the safety literature, we limited our search to review articles ("review of reviews"). Figure 3 depicts the flow of information through the different phases of the review. We did not set a date range, and we considered English-language literature in peer-reviewed journals and conferences as well as English-language books. We used the string "(reporting system OR reporting program) AND (incident OR adverse event OR error OR near miss OR sentinel event OR safety accident OR confidential OR close call OR near accident OR accident precursor OR precursor)" to search in title, abstract and keywords in the databases Web of Science (WoS), Scopus, IEEE Xplore, and ACM Digital

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

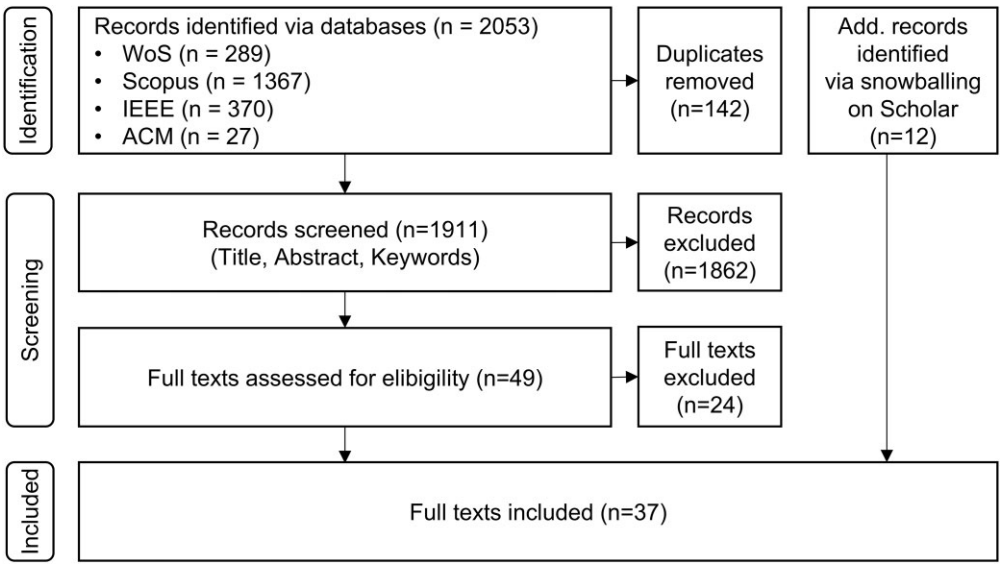


Figure 3. PRISMA flow diagram of the systematic literature review.

Library. For WoS/Scopus, the search was limited to reviews; for IEEE and ACM, "review" was added to the search string. The title, abstract, and keywords were screened for the identified articles according to the inclusion and exclusion criteria. Literature was included when it reflected on IRS in general (e.g. purpose, effectiveness, experiences, design, challenges, and recommendations). Literature that did not cover IRS, studied a single IRS (e.g. case study with lessons learned in a hospital), or analysed IRS data (e.g. classification of incident types in the aviation sector) was excluded. Afterward, full texts were retrieved and screened using the same criteria. In addition to the systematic literature review, we performed forward and backward snowballing via Google Scholar to identify foundational literature, which we considered relevant (e.g. the Handbook of Accident and Incident Reporting [23]).

The literature identified ranged from 1996 to 2023 and consisted of review articles in health care (33 full texts) and aviation (4 full texts) as well as two books on general accident reporting. On these 37 digital full texts, we performed a thematic analysis based on Braun and Clarke [80] and supported by MaxQDA software. After familiarizing ourselves with the whole data set, one researcher generated initial codes following a data-driven approach with no preconceptualized theoretical framework. Afterward, that person aggregated codes (e.g. "easy to report incident," "usability of IRS") into initial themes ("Ease of Use"). Then, the research team, consisting also of three other researchers, discussed and revised the themes.

Themes identified for the design of a reporting system

Table 2 shows each identified theme and example references, which we will discuss in the following. While some themes are typical requirements in system design (e.g. ease of use, integration, and management support), others are highly specific for incident reporting (e.g. case-based learning, impunity, and independence). The Appendix contains a complete mapping between themes and references.

Case-based learning

The main objective of an IRS should be to learn from individual cases—opposed to using it as a statistical tool or to monitor safety performance [34, 81, 82]. These individual cases allow for the identification of risk factors and the determination of the need for further investigation [81]. Ideally, reports contain information-rich narratives [83]. While traditional learning has focused on *what* to learn from a case, more recent approaches focus on *how* to learn and understand learning as an organizational process [26, 84].

Learning from individual incidents—as suggested in safety—is still considered in its infancy in cybersecurity [85–87], as the broader context of the incident is barely considered (e.g. learning processes) [42, 88]. The fact that information about attacks are often considered private and confidential, for example, to prevent additional attackers from learning about an uncovered vulnerability, hinders learning (e.g. via case studies), especially between organizations [89]. Yet, organizations would highly benefit from an exchange about uncovered vulnerabilities that might affect systems or processes across organizations. Instead, information is reduced to statistics with sometimes questionable informative value [90]. Notwithstanding, there are also good examples of in-depth analysis following a cyber incident, such as the investigation in the wake of Log4j [91]. However, there is still potential for a better understanding of the causes of cyber incidents and the question of *how* learning processes are designed.

Competence

In safety, potential reporters (e.g. nurses, pilots, and factory workers) need to know that reporting is possible, what the purpose of reporting is, and what can be reported [92–94]. This cannot simply be assumed. Expertise is also required to be able to assess whether an incident has occurred (as prerequisite to reporting it) and to analyse it [82]. For example, in the ASRS, reports are independently judged by two experienced analysts (e.g. retired pilots or air traffic controllers) to ensure intersubjective verifiability [95]. Furthermore, the incident investigators' multidisciplinary competencies have also been emphasized [83, 84, 96]. In conclusion, staff training is essential to build competences [93].

In cybersecurity, incidents are often difficult to recognize as they are "invisible" without technical expertise (e.g. analysing log files) [17 ,97]. Even when initial anomalies are observed, it is often

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

Table 2. Relevant themes for the design of IRS (alphabetical order).

Theme	Description	Example references
Case-based learning	Learning from individual cases (e.g. reporters' stories) is the primary objective of reporting.	[23, 81]
Competence	Reporters/investigators need knowledge and skills related to the IRS and reporting/investigation of incidents (e.g. how to report incidents).	[163, 92]
Confidentiality	Reports should be handled confidentially and should include information on the reporting individual/organization as well as the reported content (e.g. threats, victim data).	[107, 102]
Ease of use	IRS should be user-friendly, making it easy to report incidents.	[102, 164]
Feedback	The system should provide feedback to reporters and other relevant stakeholders (e.g. analysis results)	[81, 95]
Impunity	The reporting individual and organization should be protected from blame and penalties (e.g. through immunity).	[127, 117]
Independence	An IRS should be independent of entities with conflicting interests and without the power to discipline the reporter (i.e. separated from line management or enforcement agencies).	[127, 83]
Integration	An IRS should be integrated with other safety measures, such as monitoring and risk management, and should align with work practices within the organization and other organizations in the same sector.	[108, 82]
Management support	Management should raise awareness for safety, adopt a shared accountability stance, and provide the necessary resources (for reporters) despite potential goal conflicts (e.g. productivity versus safety).	[22, 36]
Shared ownership and accountability	A sense of ownership and accountability should be distributed between the reporter and the receiving organization.	[127, 83]
Speed and adaptivity	After each report, an investigation, necessary improvements, and feedback should be conducted promptly. The system should also adapt to a changing understanding of what an incident is and what its causes or corrective action might be.	[107, 84]
Standardization	There should be standards for what and how to report and proceed with the investigation (e.g. through policies, guidelines, and taxonomies).	[26, 147]
System-orientation	The IRS should be based on a holistic rather than a narrow understanding of an incident and its causes. Recommendations derived from analysing reports should also focus on systematic changes (e.g. ineffective control processes or security strategy).	[113, 165]
Voluntariness	Whenever possible, reporting should be voluntary to prevent biased reports, information loss, or overreporting of irrelevant incidents.	[127, 83]

unclear whether a security incident has occurred [98, 99]. Sometimes, an incident and its effects are recognized with a significant delay, for example, when attackers remain undetected after their initial intrusion. Accordingly, a high level of competence and, therefore, training is also required on the part of reporters and analysts in cybersecurity (e.g. to engage employees and laypeople in reporting [71, 100]). As cyber incidents are not purely technical phenomena but also involve human and organizational factors, interdisciplinary skills are increasingly being called for [16, 31]. However, organizations often only have technical security skills [101]. Especially small- to medium-sized organizations might lack the budget and personnel to provide the interdisciplinary skill set needed to address the intersection of technical, organizational, and human factors [87].

Confidentiality

In safety, most systems allow confidential reporting, and some even anonymous reporting [102, 83]. Confidentiality or anonymity for the reporter and the content reported may be the only way a reporter will provide insight. However, due to the lack of contextual information, anonymous reporting makes it more difficult to investigate an incident [23]. A compromise is to anonymize the reports after receiving them [102].

Confidentiality is even more crucial in cybersecurity to avoid sharing knowledge with attackers and motivate further attack [89, 103]. The high need for protection against threat actors might explain why reporting and information sharing is challenging. Also the circle of recipients of reports and the criticality of the information must be defined very precisely (e.g. with classification standards) [89, 104]. Few reporting systems allow anonymous reporting [105]. Apart from losing contextual information, this may exempt reporters from legal obligations, and lead to noncompliance with policies [106]. However, in some cases this may be the only way to collect reports [73, 78]. In summary, confidentiality—and probably anonymity—are central characteristics of reporting in cybersecurity, too.

Ease of use

In early instances of safety reporting systems, reports were made on paper and only later electronically. In both cases, however, the ease of use is crucial and lowers the access barrier since reporting incidents is not an everyday event for many people [107, 102]. As the main objective of the IRS is the analysis of the reported incident by trained personnel, very little input should be required from the reporter (e.g. a narrative description of the incident). Making reporting too complicated by eliciting potential causes is deemed of secondary importance to simply recording the event [108]. Low-threshold reporting, which favors simplicity, is therefore central to an IRS.

Cyber incident reporting is typically not a daily routine for reporters. Sometimes, they do not even know how, to whom to report, and what to report [73, 87]. Phishing reporting illustrates the importance of making the reporting process straightforward—for example, through reporting buttons in email clients [8, 109]. This principle similarly applies to employees' reporting of cybersecurity incidents

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

more broadly [100]. However, it is not equally easy to report incidents in all organizations [87].

CSIRTs have advocated low reporting thresholds to avoid making reporting unnecessarily complicated [64]. Users are encouraged to report incidents through simplified interfaces [110], and organizations are slowly adapting security.txt files on their servers, which contain contact information that defines how researchers can quickly identify security issues [10]. Finally, reporting to supervisory authorities is simplified through easy-to-use forms [111]. In summary, ease of use is also vital in cybersecurity, especially when laypeople are encouraged to report. To make IRS in cybersecurity more usable, expertise in user-centric design is required that, as already discussed for the aspect "competence," might be lacking in technology-focused organizations.

Feedback

In safety, feedback to reporters has been crucial as it helps to make learning from incidents a participatory practice [81, 92]. Feedback also creates shared accountability between reporters and reporting system operators, reinforcing its effectiveness. It is not only the specialists who should see analysis outcomes; employees who report incidents should be able to gain insights into outcomes to be able to recognize the value of their contribution [112, 113]. When possible, feedback is also shared with other parties for more generic learning (e.g. other departments, government agencies) [95]. In summary, a lack of feedback prevents learning, making organizations more susceptible to life-threatening accidents and lawsuits. Therefore, feedback within an IRS is central to turning isolated learning into organizational learning.

One could argue that feedback is even more important in cybersecurity, as many incidents occur as anomalies (e.g. high traffic on webservers) without the inherent feedback often associated with personal safety (e.g. emergency braking) [31]. However, reporters are not always acknowledged for their actions, nor are they notified about outcomes [114]. For example, literature suggests that also security researchers who identify vulnerabilities often do not receive feedback either [12, 40]. In short, appreciative and informative feedback can reinforce learning and reporting in cybersecurity [8, 109]. Stronger communication skills are needed to provide useful feedback [101]. This might be especially relevant for the security department given that cybersecurity-related roles, such as that of the CISO are often alienated within their organizations [115] and that relationships and communication flows between employees and IT security staff are often dysfunctional [116].

Impunity

Fear of sanctions or repercussions is a common barrier to reporting [117, 118], and anticipation of legal consequences means not all incidents are reported [119] or the report might be biased in favor of those involved. Such a negative association may reduce the number of reported incidents. In response, some systems protect the reporter not only through anonymity. For example, in the case of ASRS in the US aviation sector, reporters are granted partial immunity by the Federal Aviation Administration (FAA) in some circumstances [34].

In cybersecurity, impunity for individual reporters is also crucial [31, 106]. Protecting and even praising reporters—rather than shaming them—could encourage reporting and learning [61, 120–122]. Some organizations have already adopted "blameless postmortems" in the aftermath of incidents, which focus on identifying the incident's causes [123]. Others have introduced a hall of fame for reporters [124]. Some jurisdictions have implemented whistleblower protection laws whose safeguards also extend to cybersecurity-related disclosures (e.g. EU Directive 2019/1937). Future potential lies in dedicated cybersecurity reporting infrastructures. In order to create an environment that provides "psychological safety" [125] for reporters, attitudes toward IT security staff and their relationships with reporters need to be improved in many organizations [116].

At the level of reporting by organizations, fear of consequences is also an important reason for reluctance to report serious incidents [87]. Consequently, some laws regard the self-reporting of incidents as a mitigating factor when determining fines (e.g. Article 83 of GDPR [126]).

Independence

In safety, IRS should be as independent as possible from individuals or organizations with conflicting interests or authority over the reporter [127]. For example, a direct line manager prevent unwelcome news from being passed up the hierarchy [81, 127]. Instead, reports could be made to an independent team that directly reports to senior management [81]. Here, national/sectoral IRS can offer a certain degree of independence. For example, near misses are reported via ASRS operated by NASA, which has no regulatory function or enforcement authority. NASA is therefore considered a trusted party [34]. Independent "learning bodies" similar to the ASRS in the aviation sector can also be found in other sectors, such as rail and maritime industries or healthcare [127].

The independence of reporting is critical to cybersecurity as well. For example, there is a risk that the reporter will be punished for nonculpable or nonserious errors (e.g. vulnerabilities disclosure) [120]. However, a look at the national level shows that in current cybersecurity and privacy reporting systems, incidents are typically reported to supervisory authorities that have sanctioning authority (e.g. NIS 2, GDPR) [3, 6, 41]. Therefore, it is necessary to adapt laws to be able to report noncritical incidents without potential legal consequences to independent entities.

Integration

In safety, IRS were often assumed to be sufficient as the sole tool for achieving organizational safety [82]. However, IRS should only be understood as one measure of an overarching safety system. Accordingly, they should be linked to other measures (e.g. risk management and wider safety programs) [26, 93]. For example, data from an IRS can be combined with observational studies (e.g. a survey among organizations) or automatic monitoring of incidents [23]. There is also a need to integrate the IRS with other safety practices (e.g. daily routines) and the cultural frame of those who report [112].

In cybersecurity, IRS can be understood as an integral part of cyber risk-management measures. In organizations, this integration is a significant challenge [88]. However, some organizations use reports to identify risks and prioritize investments (e.g. in training or infrastructure). Furthermore, at a national/sectoral level, IRS can be complemented with incident surveys to obtain an even more complete and less biased picture [128]. In general, IRS must also be seen as complementary to informal alternatives, such as trust groups with high levels of confidentiality (e.g. Ops-Trust, NSP-Sec, and FIRST). An IRS in security should, therefore, also be considered a central building block within a more extensive security management system.

Management support

Management attitudes and behavior can significantly influence the success or failure of reporting actions [83]. At best, management acts as a role model for safety, creates a blame-free environment, provides resources to train employees, allows time to report incidents, and helps resolve goal conflicts. At worst, management introduces

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

incentive schemes that discourage reporting or create a culture of blame and fear for reporters [94]. For this reason, sustained management support for reporters and investigators as well as safeguarding the system as a whole are crucial [83, 129, 130].

Similarly, the effectiveness of reporting in cybersecurity increases when the management prioritizes cybersecurity and does not completely delegate it to security experts [131, 132]. When supervisors actively engage in reporting, it positively influences employees' intention to report incidents themselves [100]. Dedicated management roles, such as Chief Information Security Officers, and their attitudes play a key role in incident handling [133]. Also, the decision to handle reports constructively is essential for the relationship between staff and management and the future reporting of incidents [61]. Additionally, management plays a central role in sharing incident reports with other potentially affected organizations, insurance companies, or higher-level authorities [89]. Thus, in cybersecurity, management attitudes and behavior are also critical to the success of reporting systems. That said, CISOs in organizations and related roles such as cybersecurity champions supposed to advocate security measures, such as reporting are currently criticizing the lack of support of the general management [45, 134].

Shared ownership and accountability

Shared ownership and accountability within the whole organization are necessary to promote reporting and ensure that learning occurs at all levels, including individual employees, teams, and the safety department [34, 127]. The idea of shared ownership to encourage reporting has also been called a "just culture" [50]. The reporter should feel responsible for security and reporting incidents but, at the same time, not automatically be blamed for all lapses [50]. To promote shared ownership, it has been suggested that the IRS be organized as locally and decentralized as possible instead of being a centralized and hierarchical system [26]. For example, in a hospital it could be established at each unit rather than at a central quality management department.

When implementing incident reporting in cybersecurity, ownership and accountability are crucial but also challenging. Unlike personal safety, the consequences of a cyber risk may not always affect the reporter directly, making it difficult to encourage ownership [31, 135]. Reporters might not realize that their reports are relevant to the entire organization's security [135–137] nor that they are responsible for reporting [138]. Nevertheless, some approaches try to promote ownership and accountability by making cybersecurity part of a business strategy relevant for the whole organization or through a supportive organizational culture and end-user engagement (e.g. in the development of security policies) [139, 140]. In summary, incident reporting in cybersecurity faces the challenge of balancing shared ownership and shared accountability while maintaining clear responsibilities.

Speed and adaptivity

Reports should be investigated quickly, and the results fed back to the reporter for immediate action [107, 127]. This can help reduce the loss of information (e.g. observations made by those directly involved in the incident) [36]. At the same time, the system should allow a certain degree of adaptivity [83], such as what constitutes an incident that changes over time [84].

Owing to ever-changing attacks and broad attack surfaces, speed and adaptivity are even more critical in cybersecurity as seen in events such as the 2021 Microsoft Exchange Server vulnerability [141]. However, there is a risk that existing reporting and handling processes will be overburdened by too many irrelevant reports and alerts [4, 114]. To enable a timely response to reports, it is essential to triage them into potentially security-relevant and irrelevant reports [142–144]. In the future, machine learning could be used even more to distinguish relevant from irrelevant reports, and large language models could help quickly extract structured information from narrative reports [145].

Standardization

Standardization is required to ensure the efficiency of IRS. Standardization includes a common understanding between reporters and experts about what incidents are—and when and how to report them [36, 146]. A common language provided by taxonomies, in addition to free-text narratives, can preserve the richness of narrative reports while enabling systematic organization and analysis of reported data [92, 107, 147]. However, too much standardization can also negatively affect the system. For example, asking for too much detailed information from reporters instead of short narratives can discourage reporting [81]. Accordingly, researchers call for a "pragmatic" and "flexible" standardization of reporting systems [81].

In cybersecurity, a common understanding among reporters and investigators of what cyber incidents are, when to report them, and how to process reports is equally necessary [3, 148, 149]. Various standards already exist that describe what can be reported, how serious reported issues are (e.g. CVSS), and what can be learned from incidents [142, 150]. There are different requirements for standardization of reporting for laypersons compared to experts, as well as reporting within organizations or to other entities (e.g. supervisory authorities). For some target groups, standards do not yet exist. For example, if organizations want to implement reporting systems for their employees, new standards have to be developed. However, similar to the safety scenario, reporting must not be too structured, or it will discourage reporters from coming forward [8].

System orientation

Safety science suggests that IRS should be based on a sufficiently complex understanding of the causes of incidents [127, 113]. In the early days of safety, elementary incident causation models were applied (e.g. human error, technical malfunction), and only over time were more complex incident causation models developed (e.g. the Swiss Cheese Model, STAMP) [151]. Critics therefore suggest that reports should not only be used to correct obvious errors, but also to consider changes to the overall safety management system [26].

In cybersecurity, the simplistic understanding of incidents and their causes has been criticized because instead of fostering in-depth learning, these superficial changes tend to result in the mere fixing of obvious causes [88]. However, more recently, a systemic understanding of cyber incidents that considers structural causes is becoming prevalent [16, 152]. This allows us to understand why certain types of reports recur and to adopt holistic packages of measures that address technical, human, and organizational factors [16]. That is why more people should work in cybersecurity in the future who have been trained in systemic thinking [101].

Voluntariness

Mandatory and voluntary reporting approaches have specific benefits and limitations [83]. Sometimes, an obligation to report can improve the effectiveness of an IRS [107]. Mandatory reporting might also be required by law to investigate critical incidents (e.g. with casualties) or to address the issue of underreporting. However, mandatory reporting creates new problems, such as biased information, information loss, or overreporting of irrelevant incidents [23]. For this

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

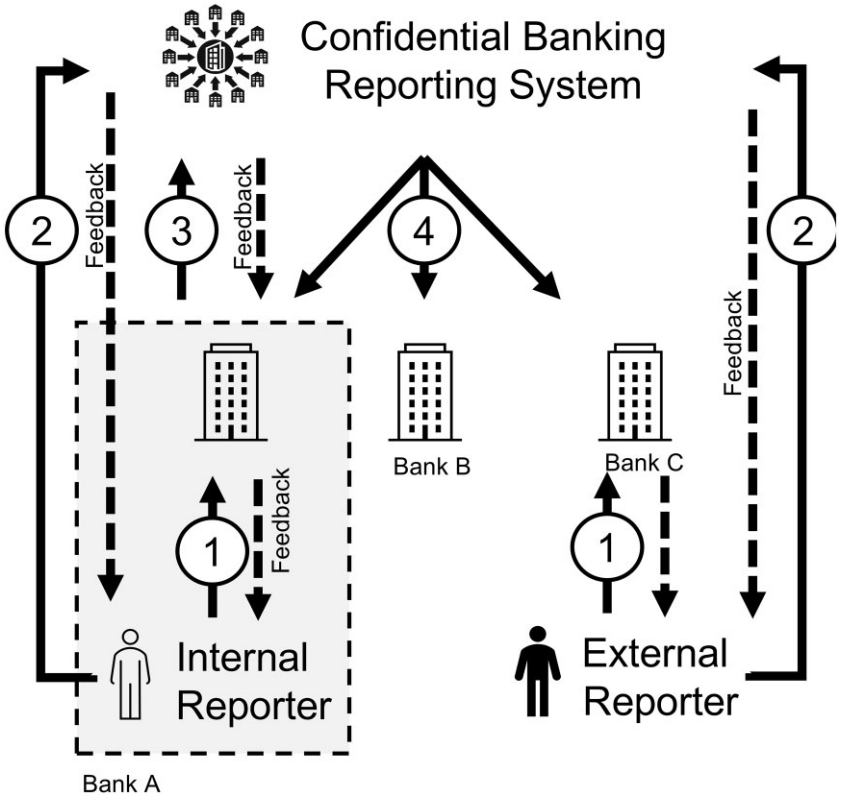


Figure 4. Illustration of a sectoral IRS in the financial sector.

reason, in mature IRS, reporting should be—whenever possible—voluntary [127].

Reporting critical cyber incidents is sometimes mandatory, too [3, 106]. While compulsory reporting typically refers to critical incidents, it has been suggested that organizations should also be obliged to report noncritical incidents (e.g. near misses) [3, 153]. However, experience from the safety sector suggests that mandatory reporting does not necessarily lead to better reports. Authors, therefore, suggest that voluntary reporting in combination with confidentiality and/or protection from sanctions should be prioritized [29, 31, 106].

If incident reporting is to be strengthened within organizations, it is important to understand that for employees, security is often only a secondary task [154]. Ultimately, a reduction in the primary task (e.g. less stress caused by business goals) is a prerequisite for more secure employee behavior [155, 156] including voluntary reporting.

Illustration of identified themes

We illustrate the themes with an example from the financial sector (Fig. 4). Practitioners, researchers, and authorities have called for sectoral CSIRTs (Financial Stability Board, 2021 [76]). Sectoral CSIRTs for critical sectors, such as the banking sector have been implemented in many countries [157]. The depicted banking CSIRT is a standalone entity and—and unlike other sectoral IRS—not hosted at a national agency with law enforcement capabilities (following the role of model of ASRS). The CSIRT acts within a predefined legal framework and is funded by the participating banks [76]. It focuses only on the voluntary and confidential reporting of noncritical incidents without significant adverse impact following the design factors mentioned earlier in this article. The system is nonpunitive and independent from supervisory authorities to protect reporters (Themes: "Independence," "Impunity"). Every reporter receives feedback (Fig. 4, dashed arrows) to encourage shared ownership (Themes: "Feedback," "Shared Ownership and Accountability"). Reporters must not only be aware of the system, what to report and what is expected from them (Themes: "Competence," "Shared ownership and Accountability"). Reporting should also be as easy as possible (Theme: "Ease of Use"). Internal staff and external reporters can not only report to an individual organization (Fig. 4, 1), which reports to the central system (Fig. 4, 3). Following the idea of systems like ASRS, they can also report anonymously to the sectoral system to protect internal reporters (Fig. 4, 1) (Theme: "Confidentiality"). All reported information is shared among the organizations (Fig. 4, 4). The IRS shown can also be connected to national IRS to exchange certain information confidentially (e.g. typical threats). The advantages of the illustrated IRS are that the participating banks can exchange information on noncritical incidents in a timely manner. A high degree of confidentiality should encourage reporting and enable joint learning from a large number of noncritical incidents that have no legal consequences.

Key findings: future potential for IRS in cybersecurity

The human ability to detect and report incidents is central to maintaining and improving cybersecurity [4, 5]. Despite numerous technological advances, such as the use of AI in threat detection, cybersecurity cannot do without human factors such as experience and intuition when it comes to recognizing threats and possible ways to mitigate them [5, 13, 158]. However, it is unclear how an effective IRS can be designed for cybersecurity. This starts with the fact that there is no clear terminology around reporting, that different forms of reporting emerge but are viewed in isolation, and that cybersecurity

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

personnel are often highly technical and have a limited understanding of socio-technical systems [101].

We addressed these challenges by drawing upon decades of experience in the field of safety in designing IRS tailored to human reporters. This analogy-based approach can be seen as complementary to other approaches, for example, an empirical evaluation of cybersecurity reporting policy [87]. Safety is the discipline that has similar problems and approaches to solutions, but is highly interdisciplinary [46] and has decades of experience with the design of reporting systems on all organizational levels [23]. Notably, many mistakes in dealing with reporting systems have already been made. In the past, IRS have been hailed as the solution to all safety problems and later perceived as filing cabinets of irrelevant reports [81]. Finally, a realistic perspective has emerged and the systems have become established with a wealth of experience in their (mis)design.

Therefore, safety knowledge offers solutions to strengthen cybersecurity reporting and improve incident information, which is currently often sparse and unreliable [90, 153, 159]. Many individuals and organizations hesitate to report incidents [87]. While other disciplines, such as organizational science, information systems, or psychology could also help to design IRS, we believe that the priority should initially be on safety science. Only in this discipline has the IRS phenomenon, which is identical to cybersecurity, already been studied to its full extent.

With growing cyber threats and the increasing importance and maturity of incident reporting in cybersecurity, now is the right time to leverage interdisciplinary experience of the sister discipline.

Our findings and their contribution to cybersecurity can be summarized as follows:

Finding #1: various existing reporting mechanisms can be grouped under the umbrella of IRS, a concept well established in safety. The objective of an IRS is to uphold and improve cybersecurity by systematically learning from reports made on different organizational levels [23].

Solution #1: the advantage of this abstract perspective is that IRS are not seen as isolated and independent phenomena, but as instances of a similar socio-technical system. For example, mechanisms ensuring timely feedback in IRS are equally important for employees that report phishing mails as for external parties that report vulnerabilities [12, 114]. If these are equally understood as IRS of an organization, care can be taken to ensure that efficient feedback mechanisms are implemented in both cases.

Finding #2: using the Swiss Cheese Model to systematically classify what can be reported in IRS, we proposed a reporting taxonomy and found potential in reporting noncritical events. For example, near misses are rarely reported to national CSIRTs [3, 29].

Solution #2: the proposed taxonomy helps to significantly increase the number of events from which to learn, beyond learning from critical incidents that represent rare learning opportunities [63]. Indeed, the first companies have begun to define near misses for their context, such as a prevented malware execution, and started to track them [62].

Finding #3: in both safety and cybersecurity, local IRS in organizations and higher-level IRS have been implemented. For example, individual organizations can maintain CSIRTs while at the same time participate in higher-level CSIRTs that span multiple organizations in the same sector. In cybersecurity, not all reporting channels are existing or elaborated.

Solution #3: internal and external reporters should be supported with improved reporting channels (e.g. employee reporting beyond phishing) [12, 71, 73]. Reporting also noncritical incidents to sectoral or national CSIRTs still has room for improvement [3]. Even whistleblowing systems like the ASRS could be implemented in sectors, where security is very important. Similar to reporting noncritical events, the expansion of reporting channels creates additional learning opportunities [63].

Finding #4: various factors are relevant for the design of effective IRS. For example, it is recommended that reporting should be voluntary wherever possible, feedback should be provided and that appropriate trust-building mechanisms such as confidentiality, impunity, and independence should be anchored in the system [34, 81]. Automatization and additional IT staff is required to follow up on reports in a timely manner.

Solution #4: these factors should be considered when improving existing and designing new IRS. For example, mandatory reporting systems for noncritical incidents to nonindependent bodies—as recently proposed in connection with the NIS 2 Directive [3]—might be ineffective as reporters may fear negative consequences. Legislation should study the case of ASRS, which only became successful when it was moved from FAA to the independent NASA [34].

Strengths and limitations

This review integrates principles from safety science into cybersecurity, presenting a novel interdisciplinary perspective. Through a comprehensive literature review and thematic analysis, we lay a robust foundation for our findings. Overall, we address significant gaps in cybersecurity practices, proposing scientifically grounded solutions to improve reporting efficacy and learning opportunities, which can directly be applied in industry.

However, the review has also several limitations. Theoretical knowledge transfer from safety cannot replace original evidence of what makes IRS effective in cybersecurity. However, we believe it still offers valuable starting hypotheses due to strong parallels. In addition, subjectivity is inevitable in the selection, interpretation, and synthesis of the vast safety literature, especially since some areas, such as aviation incident reporting, are underrepresented because we excluded gray literature (e.g. NASA technical reports). Despite these limitations, leveraging decades of safety-related experience to improve incident reporting in cybersecurity remains a worthwhile endeavor.

Avenues for future work

Numerous follow-up questions arise for practitioners and researchers. These begin with the precise definition of terms. For example, organizations need to agree on what constitutes a near miss in cybersecurity. We have provided several examples, however these definitions are highly context specific. From the perspective of a highly regulated financial institution, a near miss may be defined differently than from the perspective of a hospitality organization.

It is also conceivable that the taxonomy can be further refined to be better tailored to organizations. For example, the Human Factors Analysis and Classification System, which is based on the Swiss Cheese Model, distinguishes between factors at different organizational levels that promote an incident [160]. Poor management or insufficient resources, for example, can be latent accident factors just as much as individual employee behavior. This would also make it easier to identify weaknesses within the organization.

Furthermore, some reports of noncritical events and latent factors might qualify as “leading indicators” that predict critical incidents while others might not. For example, no evidence was found in the safety domain that noncritical events are generally good predictors of critical events [36, 161]. These correlations should also be understood in cybersecurity to prioritize reports, derived measures,

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

and identify leading indicators. For example, spear phishing mails might be better predictors of critical incidents than generic phishing emails.

Other questions relate to the identified design factors. For example, confidentiality within the IRS is crucial to ensure that the IRS itself is not a vulnerability. At the same time, reports should contain as much contextual and potentially sensitive information as possible to maximize case-based learning [23]. A question is how to mitigate these conflicts. Studies also suggest that even in safety, case-based learning from reports is sometimes rather superficial (single-loop learning) [26]. Also in cybersecurity, it is necessary to investigate how more extensive learning from reports is possible in cybersecurity (double-loop learning) [133]. Finally, we have also identified "integration" as an important factor. Further research can focus on how IRS and their reports can be better integrated into the risk and security management of organizations. For example, even if not all noncritical incidents might leading indicators for critical incidents they still could be used to improve risk management.

Conclusion

Leveraging insights from safety science, this article emphasizes the potential of IRS to transform cybersecurity practices. Our findings suggest that different forms of incident reporting should be seen as variations of the same phenomenon. This perspective provides opportunities for new approaches, such as near-miss reporting and sets requirements for how the reporting systems should be designed: reporting should be voluntary, confidential, and easy, with reporters protected from negative consequences. Investigations must be timely and focused on holistically learning from individual cases, and reporters should receive feedback.

IRS should rely on standards, be integrated with other security measures, and remain independent of entities with the power to discipline reporters. Management should raise awareness of the IRS and actively support its implementation. Reporters and investigators require relevant knowledge and skills for effective reporting and investigation. Lastly, ownership and accountability should be shared between reporters and the receiving organization to ensure participative learning.

Acknowledgments

We would like to thank the following cybersecurity practitioners and researchers for their ideas and feedback: Serge Droz, Umberto Annino, Sokratis Katsikas, and Michael Kemmer. We would also like to thank the reviewers, who contributed to the significant improvement of the manuscript.

Author contributions

Nico Ebert (Conceptualization [lead], Data curation [lead], Formal Analysis [lead], Funding acquisition [lead], Methodology [lead], Writing – original draft [lead]), Thierry Schaltegger (Conceptualization [supporting], Formal Analysis [supporting], Visualization [supporting]), Benjamin Ambuehl (Formal Analysis [supporting], Methodology [supporting], Writing – review & editing [supporting]), Tim Geppert (Formal Analysis [supporting], Writing – review & editing [supporting]), Ariane Trammell (Visualization [supporting], Writing – review & editing [supporting]), Melanie Knieps (Writing – review & editing [supporting]), Verena Zimmermann (Visualization [supporting], Writing – review & editing [supporting]).

Conflict of interest: The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Funding

This research was funded by the Swiss National Science Foundation (grant number 207550) and the Digitalization Initiative of the Zurich Higher Education Institutions (DIZH).

Appendix

Table A1 shows various near-miss and accident definitions in safety. They all characterize near misses as incidents with potentially significant adverse impacts. Only the WHO defines near misses not in terms of their potential, but in the sense that they have not exceeded certain limits or lines of defense (i.e. have not reached the patient) [20]. In all definitions, a near miss might have been prevented from being critical owing to a working control and other reasons.

Table A2 shows a mapping between each of the 37 considered full texts and the identified themes.

Table A1. Near miss and accident definitions in safety.

Domain	near miss	Accident
Aviation safety [166]	An event involving a malfunction of equipment or human error in which no significant damage or injuries occurred but which, under other circumstances, could have been an accident and which has significance to safety.	An accident is an occurrence in which there is substantial damage to an aircraft and/or injury or death to a person or persons.
Occupational safety [167]	An incident where no injury or ill health occurs but has the potential to do so may be referred to as a near-miss.	An incident where injury and ill health occur is sometimes referred to as an "accident."
Occupational safety [168]	An incident that could have caused serious injury or illness but did not is also called a "near miss."	A work-related event in which an injury or ill-health (regardless of severity) or fatality occurred or could have occurred.
Patient safety [20].	Near miss: an incident that did not reach the patient (for example, a unit of blood being connected to the wrong patient's intravenous line, but the error was detected before the transfusion started).	No-harm incident: one in which an event reached a patient, but no discernable harm resulted (for example, if the unit of blood was transfused but was compatible). Harmful incident: an incident that harms a patient (for example, the wrong unit of blood was transfused, and the patient died from a hemolytic reaction).

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

Table A2. Design themes identified in the safety literature.

Literature/theme	Case-focused	Competence	Confidentiality	Ease of use	Feedback	Impunity	Independence	Integration	Management support	Shared ownership and accountability	Speed and adaptivity	Standardization	System orientation	Voluntariness
[22]	x				x	x		x	x	x		x		
[127]	x	x	x	x	x	x	x	x	x	x	x	x	x	x
[129]		x	x			x			x					
[163]		x		x	x	x			x					x
[83]	x	x	x	x	x	x	x	x	x	x	x	x		x
[95]		x			x	x						x		x
[33]						x				x				
[169]	x	x			x	x	x					x		x
[113]		x			x	x	x				x	x	x	x
[93]	x	x		x		x		x		x		x		
[23]	x	x	x		x	x		x	x				x	
[165]		x			x	x		x	x				x	
[170]			x											x
[171]		x												
[172]						x								
[107]		x	x	x		x	x	x	x		x	x	x	x
[173]			x	x										
[130]		x			x	x			x					
[94]		x	x	x	x	x			x			x		
[146]		x	x	x	x	x			x			x		
[147]	x	x		x		x			x			x	x	
[92]	x	x	x	x	x	x			x	x	x	x		
[36]	x	x			x	x			x		x	x	x	
[84]	x	x				x					x	x		
[118]		x				x								
[81]	x				x		x	x		x		x		
[174]	x	x			x								x	
[164]	x			x	x				x					
[175]		x				x			x					
[102]	x	x	x	x		x			x		x	x		
[176]	x		x			x		x				x		
[177]	x													
[178]		x		x		x								
[108]	x	x		x	x			x						
[26]	x					x		x		x		x	x	
[82]	x	x						x						
[117]		x	x	x		x			x	x		x		
Total	19	27	13	15	18	28	6	12	18	9	8	19	9	8

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

References

1. Straub DW, Nance WD. Discovering and disciplining computer abuse in organizations: a field study. *MIS Quart* 1990;**14**:45–60. https://doi.org/10.2307/249307
2. Slayton R, Clarke B. Trusting infrastructure: the emergence of computer security incident response, 1989–2005. *Technol Cult* 2020;**61**:173–206. https://doi.org/10.1353/tech.2020.0036.
3. Schmitz-Berndt S. Defining the reporting threshold for a cybersecurity incident under the NIS Directive and the NIS 2 Directive. *J Cybersecur* 2023;**9**:tyad009. https://doi.org/10.1093/cybsec/tyad009
4. Alahmadi BA, Axon L, Martinovic I. *99% False Positives: A Qualitative Study of SOC Analysts' Perspectives on Security Alarms*. Berkeley: USENIX, 2022, 2783–800.
5. Schaltegger TA, Ambuehl B, Ackermann KA. *et al.* Re-thinking Decision-Making in Cybersecurity: leveraging Cognitive Heuristics in Situations of Uncertainty. In: *Proceedings of the Fifty-Seventh Hawaii International Conference on System Sciences*. Atlanta, GA: AIS, 2024.
6. Beardwood J. Cyberbreaches in critical infrastructure: it's not just about personal data breaches anymore (Part 1)—a comparison of the new security regime for critical infrastructures in Canada, USA and EU. *Comput Law Rev Int* 2023;**24**:109–14. https://doi.org/10.9785/cri-2023-240404
7. Dekker M, Liveri D, Lakka M. *Incident Reporting for Cloud Computing*. Athens: ENISA, 2013.
8. Pilavakis N, Jenkins A, Kokciyan N. *et al.* "I didn't click": what users say when reporting phishing. In: *Symposium on Usable Security and Privacy (USEC) 2023*. Reston, VA: The Internet Society, 2023, 1–13.
9. Ecabert T, Muhly F, Zimmermann V. Implications of cyber incident reporting obligations on multinational organizations headquartered in Switzerland. *Int Cybersecur Law Rev* 2024;**5**:585–614. https://doi.org/10.1365/s43439-024-00129-x
10. Poteat T, Li F. Who you gonna call? An empirical evaluation of website security.txt deployment. In: *Proceedings of the Twenty-First ACM Internet Measurement Conference*. New York, NY: Association for Computing Machinery, 2021, 526–32.
11. Amir E, Levi S, Livne T. Do firms underreport information on cyber-attacks? Evidence from capital markets. *Rev Account Stud* 2018;**23**:1177–206.
12. Li F, Durumeric Z, Czyz J. *et al.* You've got vulnerability: exploring effective vulnerability notifications. In: *Proceedings of the Twenty-Fifth USENIX Security Symposium (USENIX Security 16)*. Austin, TX: USENIX Association, 2016, 1033–50.
13. Zimmermann V, Schöni L, Schaltegger T. *et al.* Human-centered cybersecurity revisited: from enemies to partners. *Commun ACM* 2024;**67**:72–81. https://doi.org/10.1145/3665665
14. Ross R, Pillitteri V, Graubart R. *et al. Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*. Gaithersburg: National Institute of Standards and Technology, 2021.
15. Dennis AR. Employees are not the weakest link: an occupational safety view of information security. *Organ Cybersecur J Pract Process People* 2024;**4**:19–31.
16. Ebert N, Schaltegger T, Ambuehl B. *et al.* Learning from safety science: a way forward for studying cybersecurity incidents in organizations. *Comput Secur* 2023;**134**:103435.
17. Johnson CW. Organisational, political and technical barriers to the integration of safety and cyber-security incident reporting systems. In: Koornneef F, van Gulijk C (eds), *Computer Safety, Reliability, and Security*. Cham: Springer International Publishing, 2015, 400–9.
18. Von Solms R, Van Niekerk J. From information security to cyber security. *Comput Secur* 2013;**38**:97–102.
19. Lindberg A-K, Hansson SO, Rollenhagen C. Learning from accidents—what more do we need to know? *Saf Sci* 2010;**48**:714–21. https://doi.org/10.1016/j.ssci.2010.02.004
20. WHO. *Patient Safety Incident Reporting and Learning Systems: Technical Report and Guidance*. Geneva: 2020.
21. Jones S, Kirchsteiger C, Bjerke W. The importance of near miss reporting to further improve safety performance. *J Loss Prev Process Ind* 1999;**12**:59–67. https://doi.org/10.1016/S0950-4230(98)00038-2
22. Ahluwalia J, Marriott L. Critical incident reporting systems. *Semin Fetal Neonatal Med* 2005;**10**:31–7. https://doi.org/10.1016/j.siny.2004.09.012
23. Johnson CW. *Failure in Safety-Critical Systems: A Handbook of Accident and Incident Reporting*. Glasgow: University of Glasgow Press, 2003.
24. NASA. *ASRS—Aviation Safety Reporting System*. Washington. https://asrs.arc.nasa.gov/ (15 August 2025, date last accessed)
25. Wachter JK, Yorio PL. A system of safety management practices and worker engagement for reducing and preventing accidents: an empirical and theoretical investigation. *Accid Anal Prevent* 2014;**68**:117–30.
26. Stavropoulou C, Doherty C, Tosey P. How Effective are incident-reporting systems for improving patient safety? A systematic literature review: incident-reporting systems for improving patients' safety. *Milbank Q* 2015;**93**:826–66. https://doi.org/10.1111/1468-0009.12166
27. NASA. *The Sterile Cockpit*. Washington: 1992.
28. Evans SM, Berry JG, Smith BJ. *et al.* Attitudes and barriers to incident reporting: a collaborative hospital study. *BMJ Qual Saf* 2006;**15**:39–43.
29. Bair J, Bellovin SM, Manley A. *et al.* That was close: reward reporting of cybersecurity near misses. *Colo Tech LJ* 2017;**16**:327.
30. Gonzalez JJ. Towards a cyber security reporting system—a quality improvement process. In: Winther R, Gran BA, Dahll G (eds), *Computer Safety, Reliability, and Security*. Berlin, Heidelberg: Springer, 2005, 368–80.
31. Johnson CW. Architectures for cyber-security incident reporting in safety-critical systems. In: Masys A (ed.), *Disaster Management: Enabling Resilience*. Cham: Springer International Publishing, 2015, 127–41.
32. Amalberti R. The paradoxes of almost totally safe transportation systems. *Saf Sci* 2001;**37**:109–26. https://doi.org/10.1016/S0925-7535(00)00045-X
33. Billings C. Some hopes and concerns regarding medical event-reporting systems: lessons from the NASA Aviation Safety Reporting System. *Arch Pathol Lab Med* 1998;**122**:214.
34. Cook RI, Woods DD, Miller C. *A Tale of Two Stories: Contrasting Views of Patient Safety*. Boston, United States: National Patient Safety Foundation at the AMA, 1998.
35. Ackoff RL. Systems thinking and thinking systems. *Syst Dyn Rev* 1994;**10**:175–88. https://doi.org/10.1002/sdr.4260100206
36. Kjellén U, Albrechtsen E. *Prevention of Accidents and Unwanted Occurrences: Theory, Methods, and Tools in Safety Management*. Boca Raton: CRC Press, 2017.
37. Bada M, Sasse A, Nurse J. Cyber security awareness campaigns: why do they fail to change behaviour?. Oxford: Global Cyber Security Capacity Centre, University of Oxford, 2015.
38. Pascoe C, Quinn S, Scarfone K. The NIST Cybersecurity Framework (CSF) 2.0. Gaithersburg: NIIST. 2024. https://doi.org/10.6028/NIST.CSWP.29
39. West-Brown MJ, Stikvoort D, Kossakowski K-P. *et al. Handbook for Computer Security Incident Response Teams (CSIRTs)*. Pittsburgh: Carnegie Mellon University, Software Engineering Institute, 1998.
40. Walshe T, Simpson AC. Coordinated vulnerability disclosure programme effectiveness: issues and recommendations. *Comput Secur* 2022;**123**:102936.
41. Markopoulou D, Papakonstantinou V, de Hert P. The new EU cybersecurity framework: the NIS Directive, ENISA's role and the General Data Protection Regulation. *Comput Law Secur Rev* 2019;**35**:105336.
42. Patterson CM, Nurse JRC, Franqueira VNL. Learning from cyber security incidents: a systematic review and future research agenda. *Comput Secur* 2023;**132**:103309.
43. Yaacoub J-PA, Salman O, Noura HN. *et al.* Cyber-physical systems security: limitations, issues and future trends. *Microprocess Microsyst* 2020;**77**:103201. https://doi.org/10.1016/j.micpro.2020.103201
44. Craigen D, Diakun-Thibault N, Purse R. Defining cybersecurity. *Technol Innov Manag Rev* 2014;**4**. https://doi.org/10.22215/timreview/835
45. Hielscher J, Menges U, Parkin S. *et al.* "Employees who Don't accept the time security takes are not aware Enough": the CISO view of Human-Centred security. In: *Proceedings of the Thirty-Second USENIX Security*

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

Symposium (USENIX Security 23). Anaheim, CA: USENIX Association, 2023, 2311–28.
46. Rae D, Dekker S. The 1900s and onward: beginnings. In: *Foundations of Safety Science*. London: Routledge, 2019, 1–21.
47. van der Westhuizen J, Stanz K. Critical incident reporting systems: a necessary multilevel understanding. *Saf Sci* 2017;**96**:198–208.
48. Underwood P, Waterson P. Accident analysis models and methods: guidance for safety professionals. Leicestershire: Loughborough University, 2013.
49. Brostoff S, Sasse MA. Safe and sound: a safety-critical approach to security. In: *Proceedings of the 2001 Workshop on New Security Paradigms*. New York, NY: ACM, 2001, 41–50.
50. Reason J. *Managing the Risks of Organizational Accidents*. London: Routledge, 2016. https://doi.org/10.4324/9781315543543
51. Havinga J, Bancroft K, Rae A. Hazard reporting: how can it improve safety? *Saf Sci* 2021;**142**:105365. https://doi.org/10.1016/j.ssci.2021.105365
52. CHIRP. CHIRP. London, 2023.
53. Bafeta A, Koh M, Riveros C. *et al*. Harms reporting in randomized controlled trials of interventions aimed at modifying microbiota. *Ann Intern Med* 2018;**169**:240–7. https://doi.org/10.7326/M18-0343
54. Ross RS. *Guide for Conducting Risk Assessments*. Gaithersburg: National Institute of Standards and Technology, 2012.
55. Johnson C, Badger L, Waltermire D. *et al*. Guide to cyber threat information sharing. *NIST Spec Publ* 2016;**800**:35.
56. Dempsey KL, Chawla NS, Johnson LA. *et al*. *SP 800-137. Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations*. Gaithersburg, MD: National Institute of Standards and Technology, 2011.
57. Woollacott E. NCSC warns organizations of cyber threat from Russian Foreign Intelligence. New York: ITPro, 2024.
58. Georgiadou A, Mouzakitis S, Bounas K. *et al*. A cyber-security culture framework for assessing organization readiness. *J Comput Inf Syst* 2022;**62**:452–62. https://doi.org/10.1080/08874417.2020.1845583
59. Renaud K, Warkentin M, Pogrebna G. *et al*. VISTA: an inclusive insider threat taxonomy, with mitigation strategies. *Inf Manag* 2024;**61**:103877.
60. Cichonski P, Millar T, Grance T. *et al*. *Computer Security Incident Handling Guide*. Gaithersburg: National Institute of Standards and Technology, 2012.
61. Renaud K, Searle R, Dupuis M. Shame in cyber security: effective behavior modification tool or counterproductive foil?. In: *New Security Paradigms Workshop*. New York, NY: Association for Computing Machinery, 2021, 70–87.
62. Niedermann L. Understanding the human factor in cyber incidents. 2023. The reference is a public presentation at the Swiss Security Awareness Day 2023 in Bern, Switzerland.
63. March JG, Sproull LS, Tamuz M. Learning from samples of one or fewer. *Organ Sci* 1991;**2**:1–13. https://doi.org/10.1287/orsc.2.1.1
64. Riebe T, Kaufhold M-A, Reuter C. The impact of organizational structure and technology use on collaborative practices in computer emergency response teams: an empirical study. *Proc ACM Hum Comput Interact* 2021;**5**:1–30. https://doi.org/10.1145/3479865
65. Vielberth M, Menges F, Pernul G. Human-as-a-security-sensor for harvesting threat intelligence. *Cybersecur* 2019;**2**:23. https://doi.org/10.1186/s42400-019-0040-0
66. Özkan BE, Bulkan S. Hidden risks to cyberspace security from obsolete COTS software. In: *Proceedings of the 2019 Eleventh International Conference on Cyber Conflict (CyCon)*. Tallinn: NATO CCD COE Publication, 2019, 1–19.
67. Allianz. Cyber risk trends 2024. Munich: Allianz Commercial, 2024.
68. Jacobs R, Haber S. Organizational processes and nuclear power plant safety. *Reliab Eng Syst Saf* 1994;**45**:75–83.
69. Bhatt S, Manadhata PK, Zomlot L. The operational role of security information and event management systems. *IEEE Secur Priv* 2014;**12**:35–41.
70. Horne B. On computer security incident response teams. *IEEE Secur Priv* 2014;**12**:13–5.
71. Ballreich FL, Volkamer M, Müllmann D. *et al*. Encouraging organisational information security incident reporting. In: *Proceedings of the 2023 European Symposium on Usable Security*. New York, NY: Association for Computing Machinery, 2023, 224–36.
72. Lee J, Wang J, de Guzman MC. *et al*. Can I help prevent data breaches in the workplace? From routine activities to extra-role security behaviors. *IEEE Trans Technol Soc* 2024;**6**:1–12.
73. Tøndel IA, Line MB, Jaatun MG. Information security incident management: current practice as reported in the literature. *Comput Secur* 2014;**45**:42–57.
74. Zalando. *Zalando: Report a Vulnerability*. Berlin: Zalando Corporate. available at: https://corporate.zalando.com/en/about-us/report-vulnerability (15 August 2025, date last accessed).
75. Andreasson A, Fallen N. External cybersecurity incident reporting for resilience. In: Zdravkovic J, Grabis J, Nurcan S. *et al*. (eds), *Perspectives in Business Informatics Research*. Cham: Springer International Publishing, 2018, 3–17.
76. Novak J, Manley B, Mcintire D. *et al*. The sector CSIRT framework: developing sector-based incident response capabilities. Technical report CMU/SEI-2021-TR-002. Pittsburgh: Carnegie Mellon University, 2021. https://doi.org/10.1184/R1/13624148.v1
77. Kannan K, Telang R. Market for software vulnerabilities? Think Again. *Manag Sci* 2005;**51**:726–40. https://doi.org/10.1287/mnsc.1040.0357
78. Cyber Security Agency of Singapore. Whistleblowing. Singapore. available at: https://www.csa.gov.sg/legislation/whistleblowing (15 August 2025, date last accessed).
79. Webster J, Watson RT. Analyzing the past to prepare for the future: writing a literature review. *MIS Quart* 2002;**26**:xiii–xxiii.
80. Braun V, Clarke V. Using thematic analysis in psychology. *Qual Res Psychol* 2006;**3**:77–101. https://doi.org/10.1191/1478088706qp063oa
81. Macrae C. The problem with incident reporting. *BMJ Qual Saf* 2016;**25**:71–5. https://doi.org/10.1136/bmjqs-2015-004732
82. Vincent C. Incident reporting and patient safety. *BMJ* 2007;**334**:51. https://doi.org/10.1136/bmj.39071.441609.80
83. Barach P, Small SD. Reporting and preventing medical mishaps: lessons from non-medical near miss reporting systems. *Br Med J* 2000;**320**:759–63. https://doi.org/10.1136/bmj.320.7237.759
84. Leistikow I, Mulder S, Vesseur J. *et al*. Learning from incidents in healthcare: the journey, not the arrival, matters. *BMJ Qual Saf* 2016;**26**:bmjqs–2015.
85. Ahmad A, Hadgkiss J, Ruighaver AB. Incident response teams—challenges in supporting the organisational security function. *Comput Secur* 2012;**31**:643–52.
86. Patterson CM, Nurse JRC, Franqueira VNL. "I don't think we're there yet": the practices and challenges of organisational learning from cyber security incidents. *Comput Secur* 2024;**139**:103699.
87. Busetti S, Scanni FM. Evaluating incident reporting in cybersecurity. From threat detection to policy learning. *Govern Inf Quart* 2025;**42**:102000. https://doi.org/10.1016/j.giq.2024.102000
88. Ahmad A, Desouza KC, Maynard SB. *et al*. How integration of cyber security management and incident response enables organizational learning. *Assoc Info Sci Technol* 2020;**71**:939–53. https://doi.org/10.1002/asi.24311
89. Laube S, Böhme R. Strategic aspects of cyber risk information sharing. *ACM Comput Surv* 2017;**50**:77:1–77:36.
90. Maschmeyer L, Deibert RJ, Lindsay JR. A tale of two cybers—how threat reporting by cybersecurity firms systematically underrepresents threats to civil society. *J Inf Technol Polit* 2021;**18**:1–20.
91. Cyber Safety Review Board. *Review of the December 2021 Log4j Event*. 2022. Report, Department of Homeland Security, Washington, D.C T.
92. Kao K, Ahmed S, Pyala R. *et al*. Incident reporting systems: how did we get here and where should we go? A narrative review. *FEM* 2022;**6**. https://doi.org/10.18502/fem.v6i4.10441
93. Burkoski V. Identifying risk: the limitations of incident reporting. *Can Nurse* 2007;**103**:12–4.
94. Health Quality Ontario. Patient safety learning systems: a systematic review and qualitative synthesis. *Ontario Health Technol Assess Ser* 2017;**17**:1–23.

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

95. Beaubien JM, Baker DP. A review of selected aviation human factors taxonomies, accident/incident reporting systems and data collection tools. *Int J Appl Aviat Stud* 2002;**2**:11–36.
96. Anderson JE, Kodate N. Learning from patient safety incidents in incident review meetings: organisational factors and indicators of analytic process effectiveness. *Saf Sci* 2015;**80**:105–14. https://doi.org/10.1016/j.ssci.2015.07.012
97. Holt TJ, van Wilsem J, van de Weijer S. *et al*. Testing an integrated self-control and routine activities framework to examine malware infection victimization. *Soc Sci Comput Rev* 2020;**38**:187–206. https://doi.org/10.1177/0894439318805067
98. Goodman MD, Brenner SW. The emerging consensus on criminal conduct in cyberspace. *Int J Law Inf Technol* 2002;**10**:139–223. https://doi.org/10.1093/ijlit/10.2.139
99. Wall DS. Cybercrime, media and insecurity: the shaping of public perceptions of cybercrime. *Int Rev Law Comput Technol* 2008;**22**:45–63.
100. Ahola K, Butavicius M, McCormac A. *et al*. Hey "CSIRI", should I report this? Investigating the factors that influence employees to report cyber security incidents in the workplace. *Inf Comput Secur* 2025;**33**:242–66.
101. Dawson J, Thomson R. The future cybersecurity workforce: going beyond technical skills for successful cyber performance. *Front Psychol* 2018;**9**:744. https://doi.org/10.3389/fpsyg.2018.00744
102. O'Leary M, Chappell SL. Confidential incident reporting systems create vital awareness of safety problems. *ICAO J* 1996;**51**:11–3.
103. Mallinder J, Drabwell P. Cyber security: a critical examination of information sharing versus data sensitivity issues for organisations at risk of cyber attack. *J Bus Cont Emerg Plan* 2014;**7**:103–11.
104. Albakri A, Boiten E, De Lemos R. Risks of sharing cyber incident information. In: *Proceedings of the Thirteenth International Conference on Availability, Reliability and Security*. New York, NY: Association for Computing Machinery, 2018, 1–10.
105. ISG. BBl 2023 2296–Bundesgesetz über die Informatio… . Memphis: Fedlex, 2023.
106. Müllmann D, Volkamer M. *Meldepflicht von IT-Sicherheits- und Datenschutzvorfällen durch Mitarbeitende—Betrachtung möglicher arbeitsrechtlicher Konsequenzen. INFORMATIK 2020*. Bonn: Gesellschaft für Informatik, Bonn, 2021, 829–40.
107. Estrada-Orozco K, Cantor Cruz F, Benavides Cruz J. *et al*. Hospital adverse event reporting systems: a systematic scoping review of qualitative and quantitative evidence. *J Patient Saf* 2021;**17**:e1866–72. https://doi.org/10.1097/PTS.0000000000000690
108. Shojania KG. The frustrating case of incident-reporting systems. *BMJ Qual Saf* 2008;**17**:400–2.
109. Lain D, Kostiainen K, Čapkun S. Phishing in organizations: findings from a large-scale and long-term study. In: *Proceedings of the 2022 IEEE Symposium on Security and Privacy (SP)*. Piscataway, NJ: IEEE, 2022, 842–59.
110. Bidgoli M, Knijnenburg BP, Grossklags J. *et al*. Report now. Report effectively. Conceptualizing the industry practice for cybercrime reporting. In: *Proceedings of the 2019 APWG Symposium on Electronic Crime Research (eCrime)*. Piscataway, NJ: IEEE, 2019, 1–10.
111. CISA. Report to CISA, Arlington. available at: https://www.cisa.gov/reporting-cyber-incident (15 August 2025, date last accessed).
112. Sanne JM. Incident reporting or storytelling? Competing schemes in a safety-critical and hazardous work setting. *Saf Sci* 2008;**46**:1205–22. https://doi.org/10.1016/j.ssci.2007.06.024
113. Brunsveld-Reinders AH, Arbous MS, De Vos R. *et al*. Incident and error reporting systems in intensive care: a systematic review of the literature. *Int J Qual Health Care* 2016;**28**:2–13. https://doi.org/10.1093/intqhc/mzv100
114. Althobaiti K, Jenkins ADG, Vaniea K. A case study of phishing incident response in an educational organization. *Proc ACM Hum Comput Interact* 2021;**5**:338:1–338:32. https://doi.org/10.1145/3476079
115. Da Silva J, Jensen RB. "Cyber security is a dark art": the CISO as Soothsayer. *Proc ACM Hum Comput Interact* 2022;**6**:1–31. https://doi.org/10.1145/3555090
116. Menges U, Hielscher J, Buckmann A. *et al*. Why IT security needs therapy. In: *Proceedings of the Computer Security. ESORICS 2021 International Workshops: CyberICPS, SECPRE, ADIoT, SPOSE, CPS4CIP, and CDT&SECOMANE*. Berlin: Springer, 2022, 335–56.
117. Vrbnjak D, Denieffe S, O'Gorman C. *et al*. Barriers to reporting medication errors and near misses among nurses: a systematic review. *Int J Nurs Stud* 2016;**63**:162–78. https://doi.org/10.1016/j.ijnurstu.2016.08.019
118. Lopez-Gonzalez E, Herdeiro MT, Figueiras A. Determinants of under-reporting of adverse drug reactions. *Drug Saf* 2009;**32**:19–31. https://doi.org/10.2165/00002018-200932010-00002
119. Bridges WG. Get near misses reported. In: *Proceedings of the International Conference and Workshop on Process Industry Incidents, CCPS/AICHE*. New York, NY: AIChE, 2000.
120. Green AW, Oliver D, Woszczynski AB. To report or not to report? Extending protection motivation theory to vulnerability discovery and disclosure. *Comput Secur* 2024;**142**:103880.
121. Jaishankar K. Cyber victimology: a new sub-discipline of the twenty-first century victimology. In: Joseph J, Jergenson S (eds). *An International Perspective on Contemporary Developments in Victimology: A Festschrift in Honor of Marc Groenhuijsen*. Cham: Springer International Publishing, 2020, 3–19. https://doi.org/10.1007/978-3-030-41622-5
122. Jensen ML, Wright RT, Durcikova A. *et al*. Improving phishing reporting using security gamification. *J Manag Inf Syst* 2022;**39**:793–823. https://doi.org/10.1080/07421222.2022.2096551
123. Lunney J, Lueder S. *Postmortem Culture: Learning from Failure*. Sebastopol: O'Reilly Media, Inc., 2017.
124. BSI. Hall of Fame. Bonn: Bundesamt für Sicherheit in der Informationstechni. https://www.bsi.bund.de/DE/IT-Sicherheitsvorfall/IT-Schwachstellen/Hall_of_Fame/Hall_of_Fame_node.html (15 August 2025, date last accessed).
125. Edmondson AC, Lei Z. Psychological safety: the history, renaissance, and future of an interpersonal construct. *Annu Rev Organ Psychol Organ Behav* 2014;**1**:23–43. https://doi.org/10.1146/annurev-orgpsych-031413-091305
126. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (Text with EEA relevance). *OJ L* 2016;**119**.
127. Arnal-Velasco D, Barach P. Anaesthesia and perioperative incident reporting systems: opportunities and challenges. *Best Pract Res Clin Anaesthesiol* 2021;**35**:93–103.
128. Department for Science, Innovation and Technology. *Cyber Security Breaches Survey 2023*. London, 2023.
129. Asgarian A, Mahjour P, Heidari H. *et al*. Barriers and facilities in reporting medical errors: a systematic review study. *Adv Human Biol* 2021;**11**:17–25. https://doi.org/10.4103/AIHB.AIHB_80_20
130. Hamed MMM, Konstantinidis S. Barriers to incident reporting among nurses: a qualitative systematic review. *West J Nurs Res* 2022;**44**:506–23. https://doi.org/10.1177/0193945921999449
131. Kemp S, Buil-Gil D, Miró-Llinares F. *et al*. When do businesses report cybercrime? Findings from a UK study. *Criminol Crim Just* 2023;**23**:468–89.
132. Rothrock RA, Kaplan J, Van Der Oord F. The board's role in managing cybersecurity risks. *MIT Sloan Manag Rev* 2018;**59**:12–5.
133. Anderson A, Ahmad A, Chang S. Case-based learning for cybersecurity leaders: a systematic review and research agenda. *Inf Manag* 2024;**61**:104015.
134. Gutfleisch M, Schöps M, Horstmann SA. *et al*. Security champions without support: results from a case study with OWASP SAMM in a large-scale e-commerce enterprise. In: *Proceedings of the 2023 European Symposium on Usable Security*. New York, NY: Association for Computing Machinery, 2023, 260–76.
135. Reeves A, Delfabbro P, Calic D. Encouraging employee engagement with cybersecurity: how to tackle cyber fatigue. *Sage Open* 2021;**11**:21582440211000049. https://doi.org/10.1177/21582440211000049

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

136. Faltermaier S, Strunk K, Obermeier M. *et al.* Managing Organizational Cyber Security—The Distinct Role of Internalized Responsibility. In: *Proceedings of the Fifty-Sixth Hawaii International Conference on System Sciences*. Atlanta, GA: AIS, 2023.
137. Smith FA. The influence of anonymity factors on IT security incident reporting. New York: Ethena, 2020.
138. Orizet J. *Datenleck bei Zürcher Badis: Daten von 45'000 Badegästen waren online*. Zurich: Netzwoche, 2023.
139. Amankwa E, Loock M, Kritzinger E. Establishing information security policy compliance culture in organizations. *Inf Comput Secur* 2018;**26**:420–36.
140. Kosutic D, Pigni F. Cybersecurity: investing for competitive outcomes. *J Bus Strategy* 2020;**43**:28–36. https://doi.org/10.1108/JBS-06-2020-0116
141. Pitney AM, Penrod S, Foraker M. *et al.* A systematic review of 2021 Microsoft exchange data breach exploiting multiple vulnerabilities. In: *Proceedings of the 2022 Seventh International Conference on Smart and Sustainable Technologies (SpliTech)*. Piscataway, NJ: IEEE, 2022, 1–6.
142. FIRST. Common Vulnerability Scoring System SIG. Cary: FIRST—Forum of Incident Response and Security Teams. https://www.first.org/cvss (15 August 2025, date last accessed).
143. Hore S, Moomtaheen F, Shah A. *et al.* Towards optimal triage and mitigation of context-sensitive cyber vulnerabilities. *IEEE Trans Depend Secure Comput* 2023;**20**:1270–85. https://doi.org/10.1109/TDSC.2022.3152164
144. Zhong C, Lin T, Liu P. *et al.* A cyber security data triage operation retrieval system. *Comput Secur* 2018;**76**:12–31.
145. López Velásquez JM, Martínez Monterrubio SM, Sánchez Crespo LE. *et al.* Systematic review of SIEM technology: SIEM-SC birth. *Int J Inf Secur* 2023;**22**:691–711. https://doi.org/10.1007/s10207-022-00657-9
146. Heavner JJ, Siner JM. Adverse event reporting and quality improvement in the intensive care unit. *Clin Chest Med* 2015;**36**:461–7. https://doi.org/10.1016/j.ccm.2015.05.005
147. Holden R, Karsh B. A review of medical error reporting system design considerations and a proposed cross-level systems research framework. *Hum Factors* 2007;**49**:257–76. https://doi.org/10.1518/001872007X312487
148. Ahmad A, Maynard SB, Desouza KC. *et al.* How can organizations develop situation awareness for incident response: a case study of management practice. *Comput Secur* 2021;**101**:102122.
149. Koivunen E. "Why Wasn't I Notified?": information security incident reporting demystified. In: Aura T, Järvinen K, Nyberg K (eds), *Information Security Technology for Applications*. Berlin, Heidelberg: Springer, 2012, 55–70.
150. Wunder J, Kurtz A, Eichenmüller C. *et al.* Shedding light on CVSS scoring inconsistencies: a user-centric study on evaluating widespread security vulnerabilities. In: *Proceedings of the 2024 IEEE Symposium on Security and Privacy (SP)*. Piscataway, NJ: IEEE, 2024, 1102–21.
151. Qureshi ZH. *A Review of Accident Modelling Approaches for Complex Critical Sociotechnical Systems*. Fairbairn: Command, Control, Communications and Intelligence Division DSTO Defence Science and Technology Organisation, 2008.
152. Khan S, Kabanov I, Hua Y. *et al.* A systematic analysis of the Capital One data breach: critical lessons learned. *ACM Trans Priv Secur* 2023;**26**:1–29. https://doi.org/10.1145/3546068
153. Cremer F, Sheehan B, Fortmann M. *et al.* Cyber risk and cybersecurity: a systematic review of data availability. *Geneva Pap Risk Insur Iss Pract* 2022;**47**:698–736. https://doi.org/10.1057/s41288-022-00266-6
154. Beautement A, Sasse A. The economics of user effort in information security. *Comput Fraud Secur* 2009;**2009**:8–12.
155. Trang S, Nastjuk I. Examining the role of stress and information security policy design in information security compliance behaviour: an experimental study of in-task behaviour. *Comput Secur* 2021;**104**:102222.
156. Kurowski S, Fähnrich N, Roßnagel H. On the possible impact of security technology design on policy adherent user behavior—results from a controlled empirical experiment. In: *SICHERHEIT2018*. Bonn: Gesellschaft für Informatik e.V., 2018, 145–58.
157. Edgars Taurins. *Sectoral CSIRT Capabilities—Energy and Air Transport*. Athens: ENISA, 2020.
158. Safi R, Browne GJ. Detecting cybersecurity threats: the role of the recency and risk compensating effects. *Inf Syst Front* 2022;**25**:1277–92. https://doi.org/10.1007/s10796-022-10274-5
159. Oppenheimer H. How the process of discovering cyberattacks biases our understanding of cybersecurity. *J Peace Res* 2024;**61**:28–43. https://doi.org/10.1177/00223433231217687
160. Shappell SA, Wiegmann DA. *The Human Factors Analysis and Classification System–HFACS*. Springfield: National Technical Information Service, 2000.
161. Marsden E. The Heinrich/Bird safety pyramid: pioneering research has become a safety myth. Risk Engineering. 2021.
163. Balan S. Knowledge, attitude and practice of Malaysian healthcare professionals toward adverse drug reaction reporting: a systematic review. *Int J Pharm Pract* 2021;**29**:308–20.
164. Mitchell I, Schuster A, Smith K. *et al.* Patient safety incident reporting: a qualitative study of thoughts and perceptions of experts 15 years after 'To Err is Human'. *BMJ Qual Saf* 2016;**25**:92–9. https://doi.org/10.1136/bmjqs-2015-004405
165. Citra Budi S, Sunartini S, Lazuardi L. *et al.* Information systems and patient safety incident reports: a systematic review of literature and observational incident reporting system in hospitals. *Int J Recent Technol Eng* 2019;**8**:807–14.
166. National Research Council. *Improving Aircraft Safety*. Washington: National Academies Press, 1980.
167. ISO/TC 283. ISO 45001:2018 Occupational health and safety management systems. Geneva: ISO, 2018.
168. OSHA. Incident [Accident] Investigations: a Guide for Employers. Washington, 2015.
169. Billings C, Cook R, Woods D. *et al.* Incident reporting systems in medicine and experience with the aviation safety reporting system. In: *A Tale of Two Stories: Contrasting Views of Patient Safety. Report from a Workshop on Assembling the Scientific Basis for Progress on Patient Safety* McLean, VA: National Patient Safety Foundation at the AMA, 1998.
170. Cui X-H, Sun N-Y, Li Y-P. *et al.* International comparative analyses of incidents reporting systems for healthcare risk management. *Chin J Evid Based Med* 2011;**11**:237–46.
171. Di Maio M, Basch E, Bryce J. *et al.* Patient-reported outcomes in the evaluation of toxicity of anticancer treatments. *Nat Rev Clin Oncol* 2016;**13**:319–25. https://doi.org/10.1038/nrclinonc.2015.222
172. Dunn D. Incident reports—correcting processes and reducing errors. *AORN J* 2003;**78**:211–33. https://doi.org/10.1016/S0001-2092(06)60772-2
173. Gong Y, Kang H, Wu X. *et al.* Enhancing patient safety event reporting a systematic review of system design features. *Appl Clin Inf* 2017;**8**:893–909.
174. Mahajan R. Critical incident reporting and learning. *Br J Anaesth* 2010;**105**:69–75. https://doi.org/10.1093/bja/aeq133
175. Nurdin DA, Wibowo A. Barriers to reporting patient safety incident in health care workers: integrative literature review. *Indones J Health Admin* 2021;**9**:210–7.
176. Pronovost PJ, Nolan T, Zeger S. *et al.* How can clinicians measure safety and quality in acute care?. *The Lancet* 2004;**363**:1061–7. https://doi.org/10.1016/S0140-6736(04)15843-1
177. Renshaw M, Vaughan C, Ottewill M. *et al.* Clinical incident reporting: wrong time, wrong place. *Int J Health Care Qual Assur* 2008;**21**:380–4. https://doi.org/10.1108/09526860810880180
178. Shafei L, Mekki L, Maklad E. *et al.* Factors that influence patient and public adverse drug reaction reporting: a systematic review using the theoretical domains framework. *Int J Clin Pharm* 2023;**45**:801–13. https://doi.org/10.1007/s11096-023-01591-z

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf019/8238596 by guest on 06 October 2026

© The Author(s) 2025. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution License (https://creativecommons.org/licenses/by/4.0/), which permits unrestricted reuse, distribution, and reproduction in any medium, provided the original work is properly cited.